

Report: Privileged Access Management (PAM)

1. Introduction

Privileged Access Management (PAM) is a critical security control within an Active Directory (AD) environment, ensuring that administrative privileges are tightly controlled, audited, and restricted to the minimum necessary scope. In this task, we implemented three key components of PAM: Just Enough Administration (JEA) to allow restricted command execution, temporary admin accounts to limit access duration, and Privileged Access Workstations (PAWs) to isolate administrative activity. Each of these mechanisms adds a layer of protection against misuse, lateral movement, and credential compromise—making the AD infrastructure more resilient to internal and external threats. For testing and validation, a cloned Windows 10 machine named PC1TEST was configured as the PAW and domain-joined to task.local.

2. Objective

The primary objective was to implement a PAM solution across three fronts. First, create a secure JEA endpoint restricting Diya.Finance's remote access to a minimal command set for helpdesk duties. Second, enforce a strict time limit on a temporary Domain Admin account to validate automatic expiry. Third, lock down access to Domain Admin privileges such that only PAW (PC1TEST) is allowed to log in locally. Collectively, these efforts simulate real-world enterprise restrictions and security boundaries that uphold Zero Trust principles.

3. Tools used

- Active Directory Users and Computers
- Group Policy Management Console (GPMC)
- PowerShell (including JEA modules)
- Windows RSAT Tools
- Windows Security Policy Editor

4. Methodology

4.1 Implement Just Enough Administration (JEA) for Helpdesk Staff

A PowerShell role capability file named HelpdeskSupport.psrc was created in the RoleCapabilities folder under a custom module called HelpdeskRole. This file defined allowed cmdlets like Get-Service and Restart-Service. A session configuration file DiyaSession.pssc was then generated using the New-PSSessionConfigurationFile cmdlet, restricting Diya.Finance's remote PowerShell session to only those capabilities. This configuration was registered under the name DiyaJEA using Register-PSSessionConfiguration. Diya.Finance successfully initiated a session with Enter-PSSession -ComputerName server1.task.local -ConfigurationName DiyaJEA and was able to execute permitted commands while others were blocked.

```
PS C:\Users\Administrator>
PS C:\Users\Administrator> New-Item -ItemType Directory -Path 'C:\ProgramData\Jea' -Force

Directory: C:\ProgramData

Mode                LastWriteTime         Length Name
----                -
d-----          5/14/2025  11:13 PM              Jea

PS C:\Users\Administrator>
```

(Creating the JEA Directory)

```
PS C:\Users\Administrator> New-PSSessionConfigurationFile -SessionType RestrictedRemoteServer -RoleDefinitions @{ 'task\Diya.Finance' = @( RoleCapabilities = 'HelpdeskSupport' ) } -Path 'C:\ProgramData\Jea\DiyaSession.pssc'
PS C:\Users\Administrator>
```

(Creating the .pssc Configuration File)

```
HelpdeskSupport.ps1 - Notepad
File Edit Format View Help
{
    GUID = 'f290d8c6-04df-4e6a-a9d6-57f241fa7b85'
    Author = 'task.local'
    CompanyName = 'task.local'
    Description = 'Helpdesk support role with service control rights'
    PowerShellVersion = '5.1'

    VisibleCmdlets = @(
        @{ Name = 'Restart-Service'; Parameters = @(@{ Name = 'Name' }) },
        @{ Name = 'Get-Service'; Parameters = @(@{ Name = 'Name' }) }
    )

    VisibleFunctions = @()
    VisibleExternalCommands = @()
    VisibleAliases = @()
}

PS C:\Users\Administrator> Restart-Service WinRM
PS C:\Users\Administrator> notepad "C:\Program Files\WindowsPowerShell\Modules\HelpdeskRole\Role
Capabilities\HelpdeskSupport.ps1"
PS C:\Users\Administrator>
```

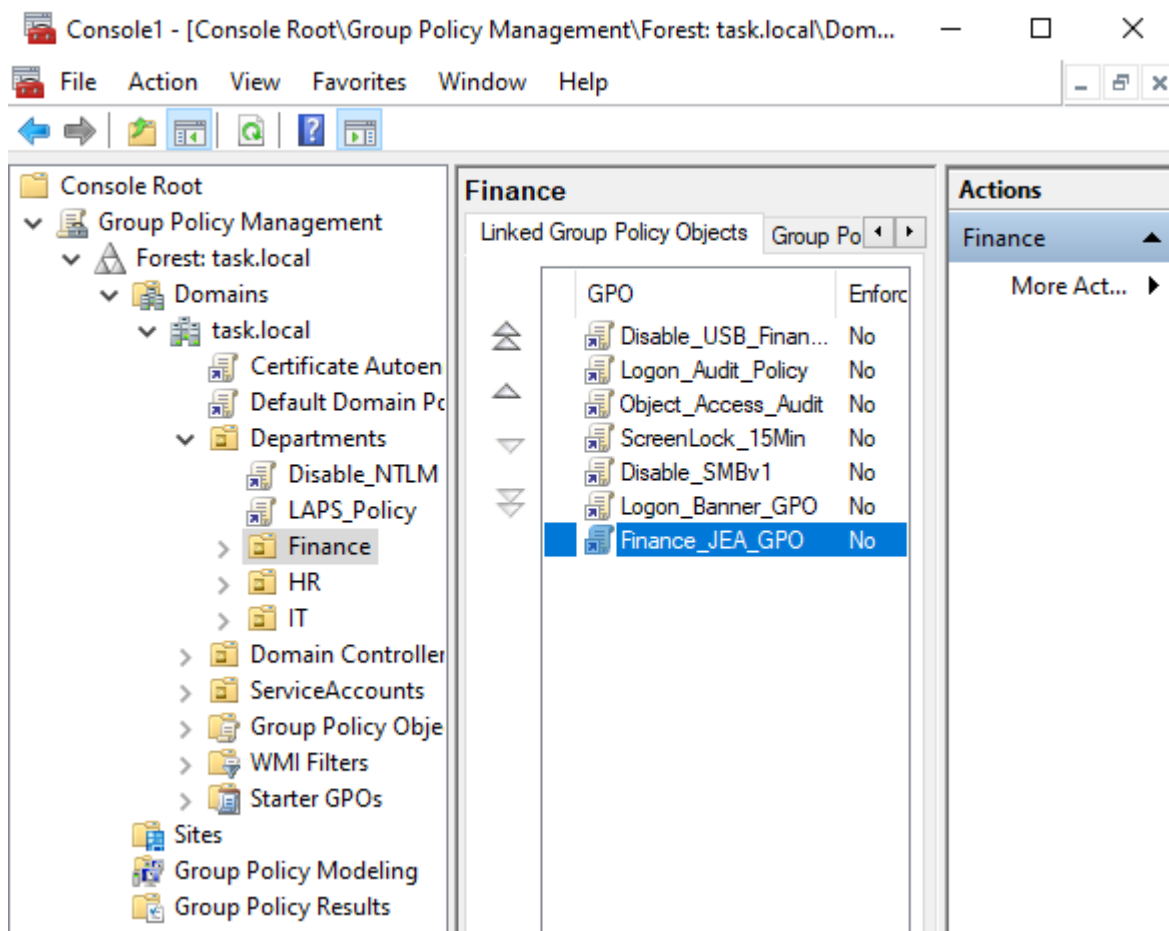
(Role Capability File)

```
PS C:\Users\Administrator> Register-PSSessionConfiguration -Name DiyaJEA -Path 'C:\ProgramData\Jea\DiyaSession.pssc'
WARNING: Register-PSSessionConfiguration may need to restart the WinRM service if a configuration using
this name has recently been unregistered, certain system data structures may still be cached. In that
case, a restart of WinRM may be required.
All WinRM sessions connected to Windows PowerShell session configurations, such as Microsoft.PowerShell
and session configurations that are created with the Register-PSSessionConfiguration cmdlet, are
disconnected.

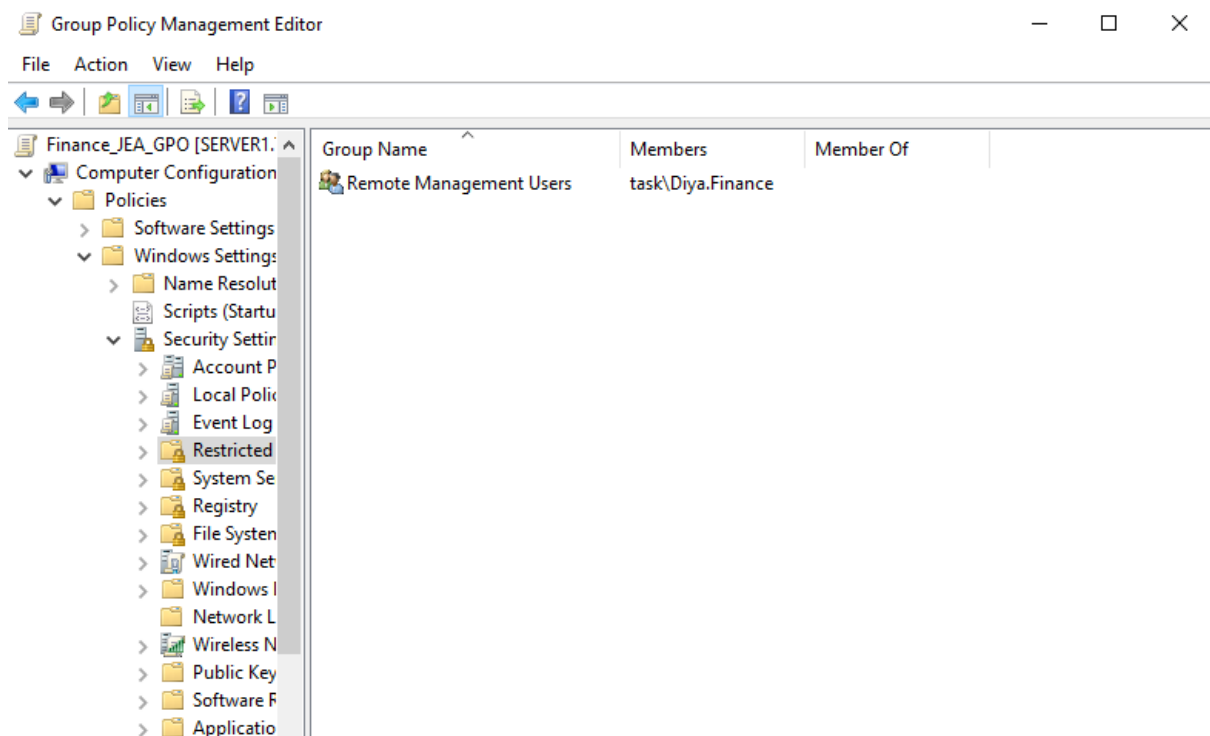
WSManConfig: Microsoft.WSMan.Management\WSMan::localhost\Plugin
Type      Keys      Name
----
Container {Name=DiyaJEA} DiyaJEA
WARNING: Set-PSSessionConfiguration may need to restart the WinRM service if a configuration using this
name has recently been unregistered, certain system data structures may still be cached. In that case, a
restart of WinRM may be required.
All WinRM sessions connected to Windows PowerShell session configurations, such as Microsoft.PowerShell
and session configurations that are created with the Register-PSSessionConfiguration cmdlet, are
disconnected.
WARNING: Register-PSSessionConfiguration may need to restart the WinRM service if a configuration using
this name has recently been unregistered, certain system data structures may still be cached. In that
case, a restart of WinRM may be required.
All WinRM sessions connected to Windows PowerShell session configurations, such as Microsoft.PowerShell
and session configurations that are created with the Register-PSSessionConfiguration cmdlet, are
disconnected.

PS C:\Users\Administrator>
PS C:\Users\Administrator>
```

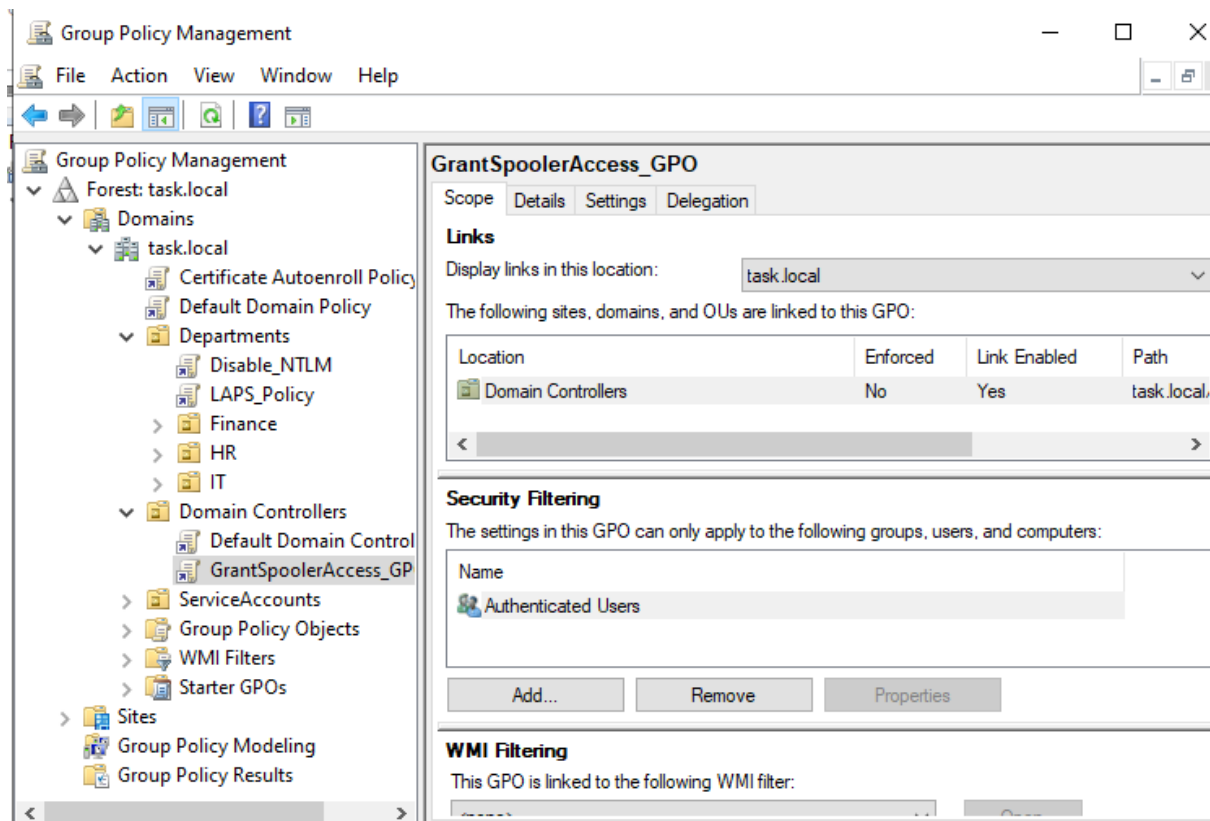
(Session Configuration Registration)



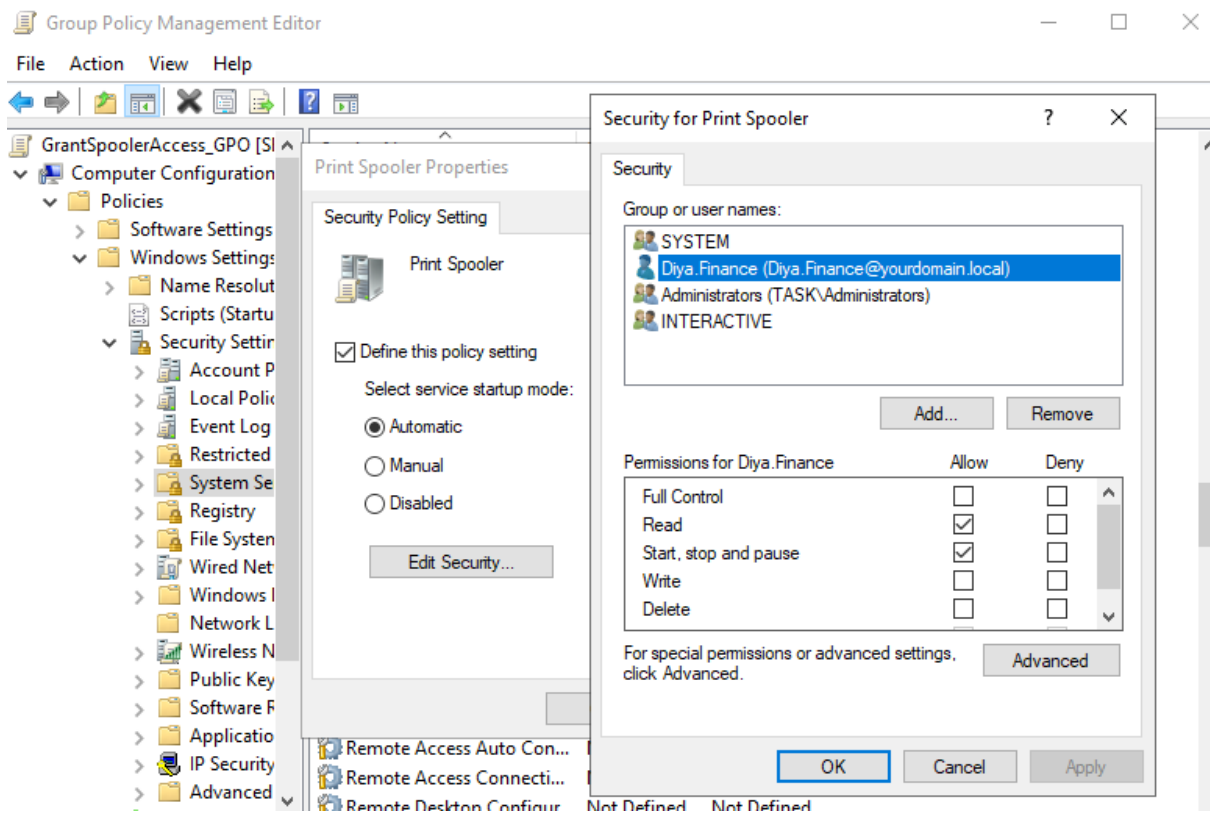
(Create a new GPO: Finance_JEA_GPO)



(Add Diya.Finance to "Remote Management Users")



(Created a new GPO for granting Permission on Print Spooler Service)



(Edit policy)

```

PS C:\Users\Diya.Finance>
PS C:\Users\Diya.Finance> Enter-PSSession -ComputerName server1.task.local -ConfigurationName DiyaJEA
[server1.task.local]: PS>Restart-Service spooler
WARNING: Waiting for service 'Print Spooler (spooler)' to start...
[server1.task.local]: PS>Get-Service spooler

Status      Name      DisplayName
-----
Running     spooler    Print Spooler

[server1.task.local]: PS>

```

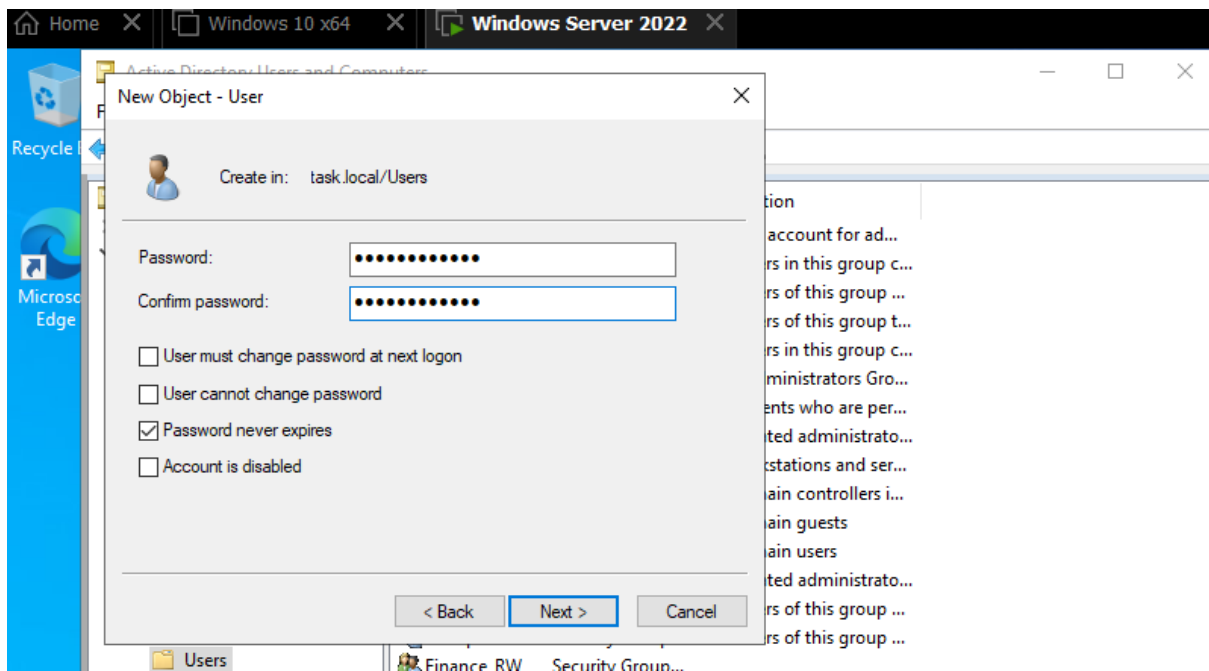
(JEA Session Active from Diya.Finance

Allowed Command Execution (Inside JEA)

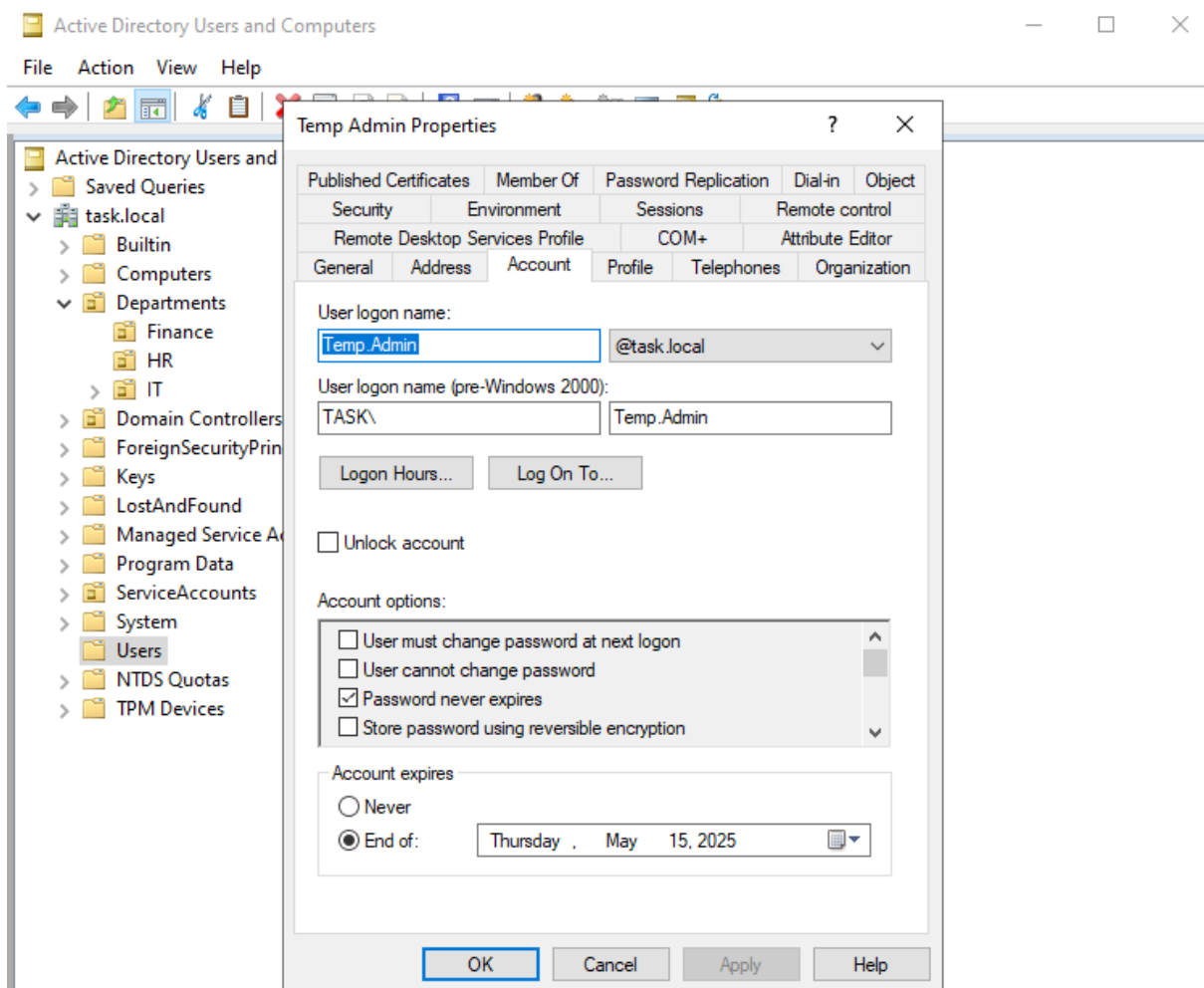
Restart-Service spooler and Get-Service spooler)

4.2 Create Time-Limited Admin Accounts

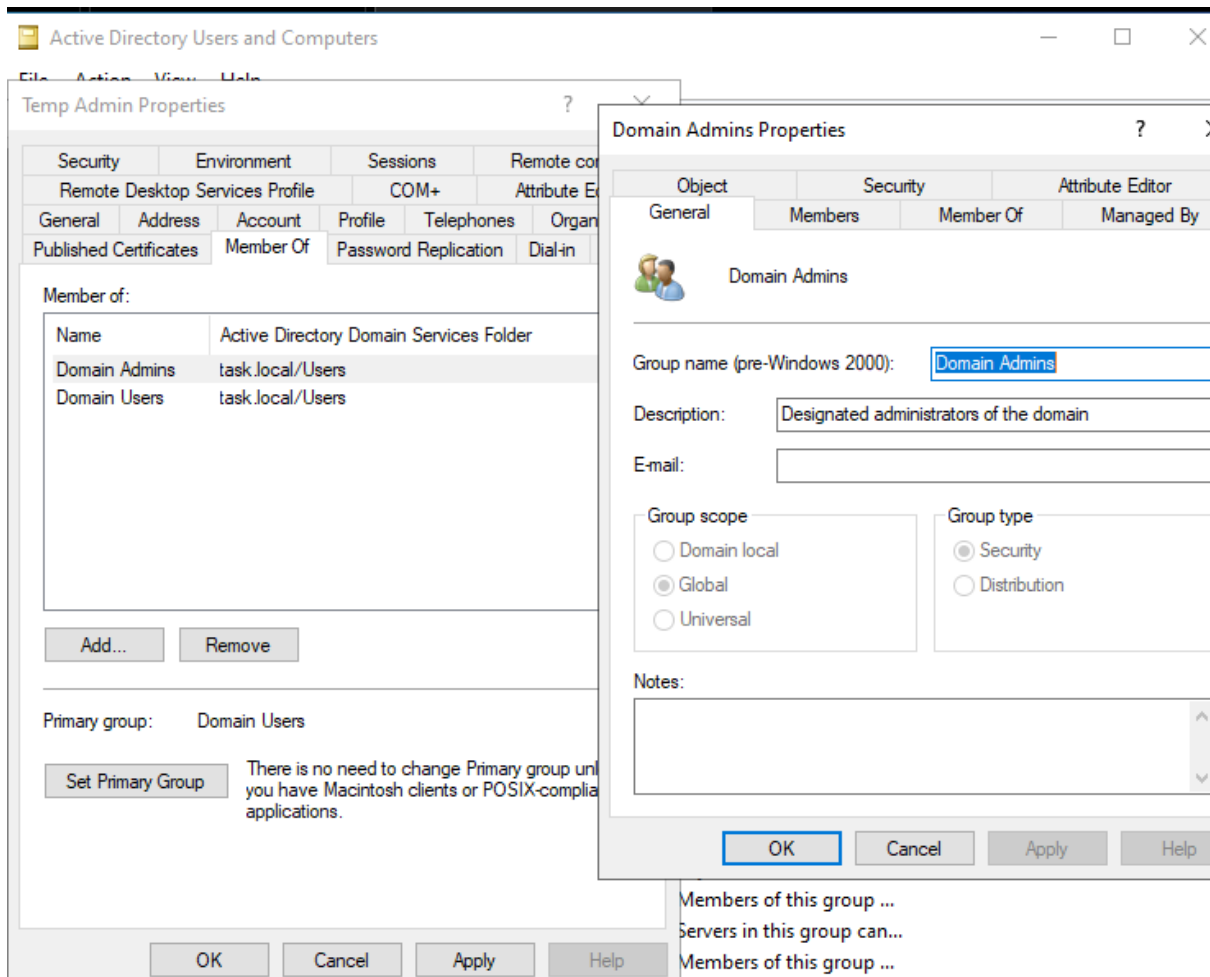
A temporary administrative user named Temp Admin was created and added to the Domain Admins group. The expiration was set using PowerShell with the Set-ADUser cmdlet. The time was set to 2 minutes for testing using the command \$expiry = (Get-Date).AddMinutes(2) followed by Set-ADUser -Identity "Temp.Admin" -AccountExpirationDate \$expiry. After the expiration time passed, attempts to log in resulted in an error stating the account had expired, confirming the account lockout functionality.



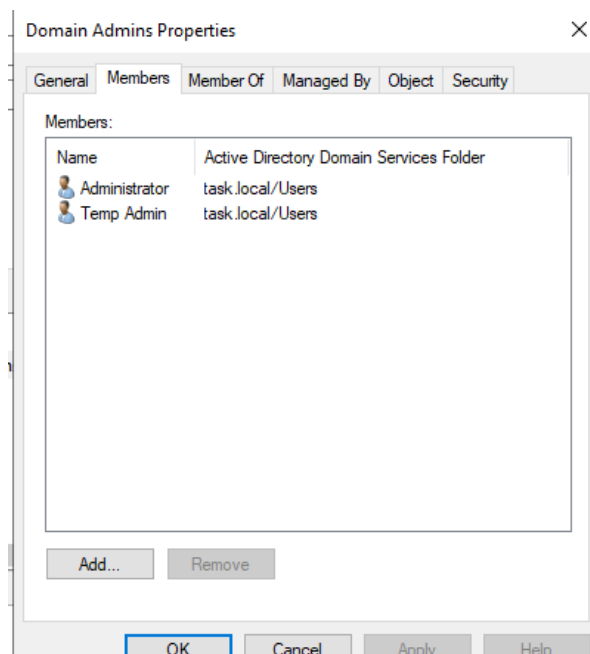
(Create a new user with password never expire for testing)



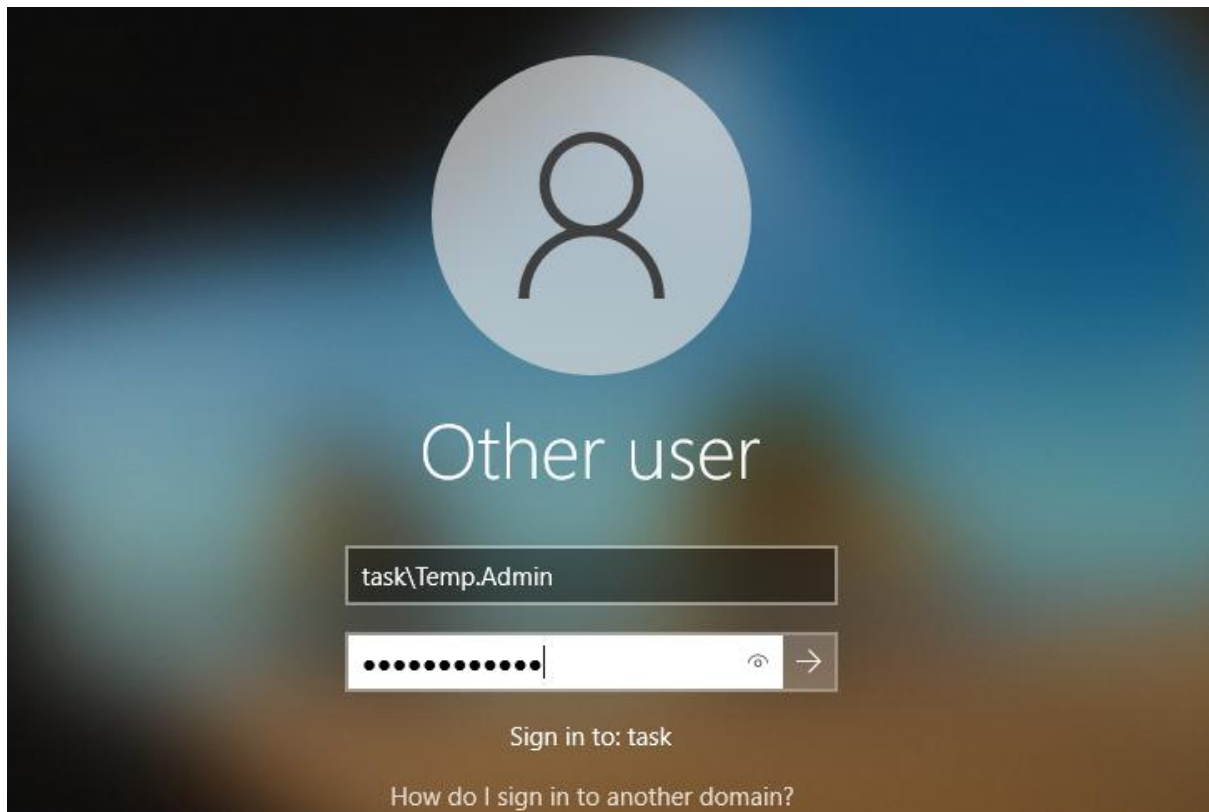
(Set expire date of today)



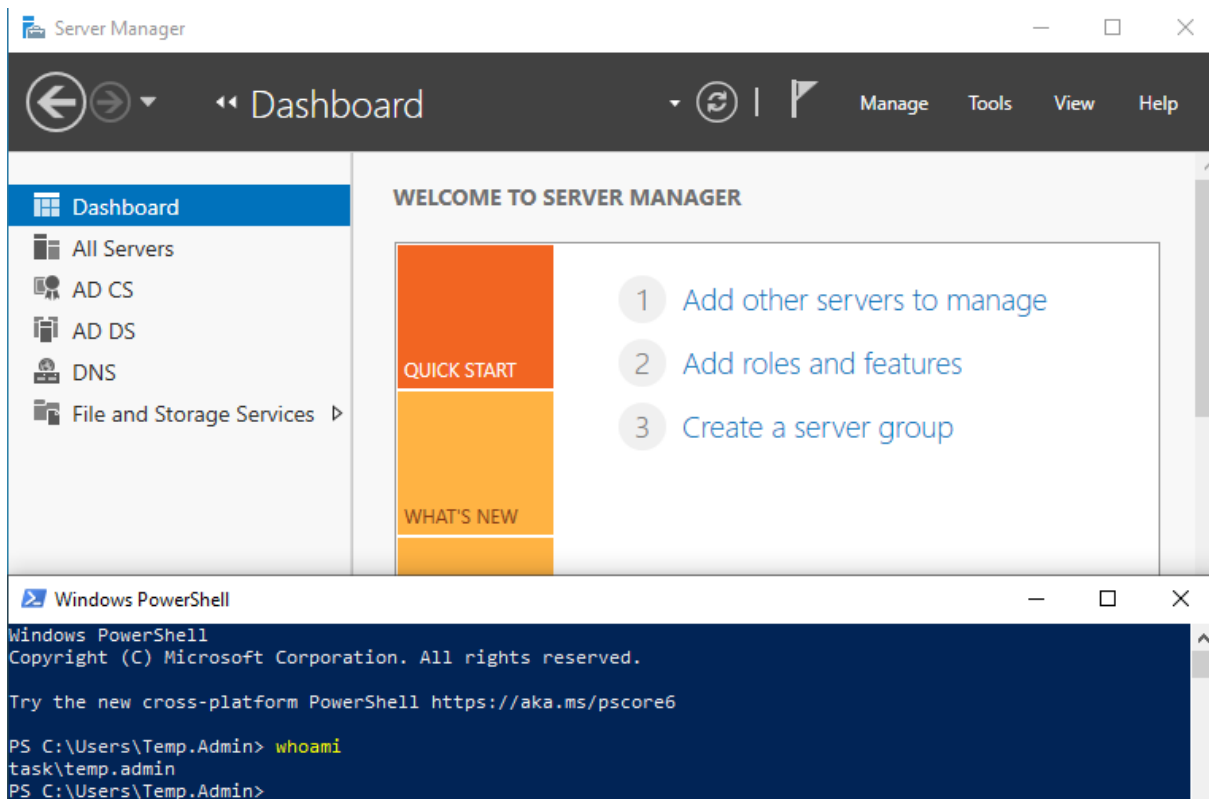
(Make this user member of Domain Admins for testing purpose)



(Verified user is now member of Domain Admins)



(Sign in as temp admin in PC1)



(Verified we have admin rights in this account)

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\Temp.Admin> Get-ADUser Administrator

DistinguishedName : CN=Administrator,CN=Users,DC=task,DC=local
Enabled           : True
GivenName        :
Name             : Administrator
ObjectClass       : user
ObjectGUID        : a14bd2d1-5d5c-4012-bf0f-12c6202fa340
SamAccountName    : Administrator
SID              : S-1-5-21-2559830969-548201595-822421515-500
Surname          :
UserPrincipalName :

PS C:\Users\Temp.Admin>
```

(Admin commands are working properly)

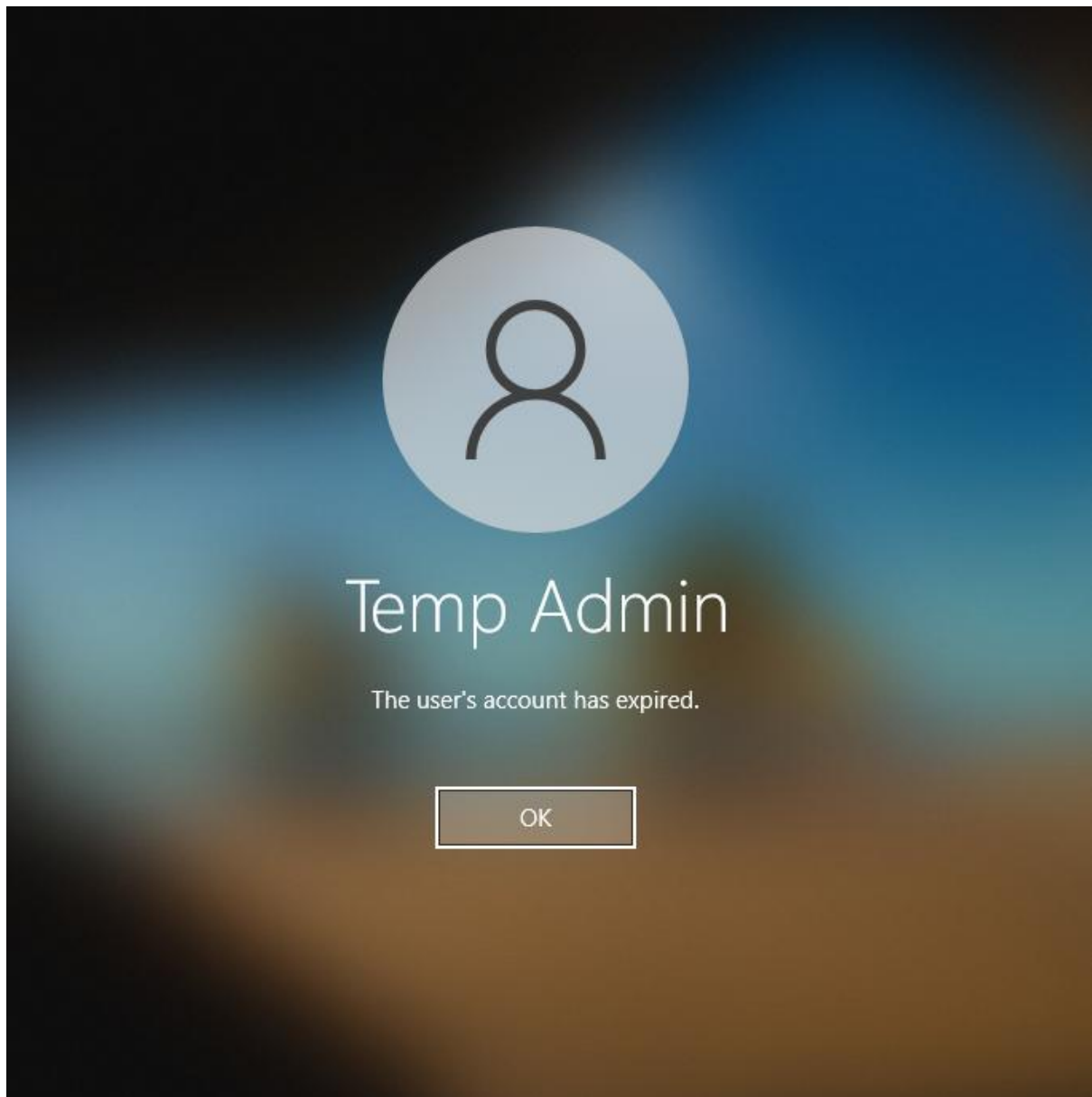
```
Administrator: Windows PowerShell

PS C:\Users\Administrator> Set-ADUser -Identity "Temp.Admin" -AccountExpirationDate (Get-Date).AddMinutes(2)
PS C:\Users\Administrator> Get-ADUser Temp.Admin -Properties AccountExpirationDate | Select Name, AccountExpirationDate

Name      AccountExpirationDate
----      -
Temp Admin 5/15/2025 2:12:52 AM

PS C:\Users\Administrator>
```

(For testing the purpose we set expiration time to 2 minutes we can set it as long as we like)

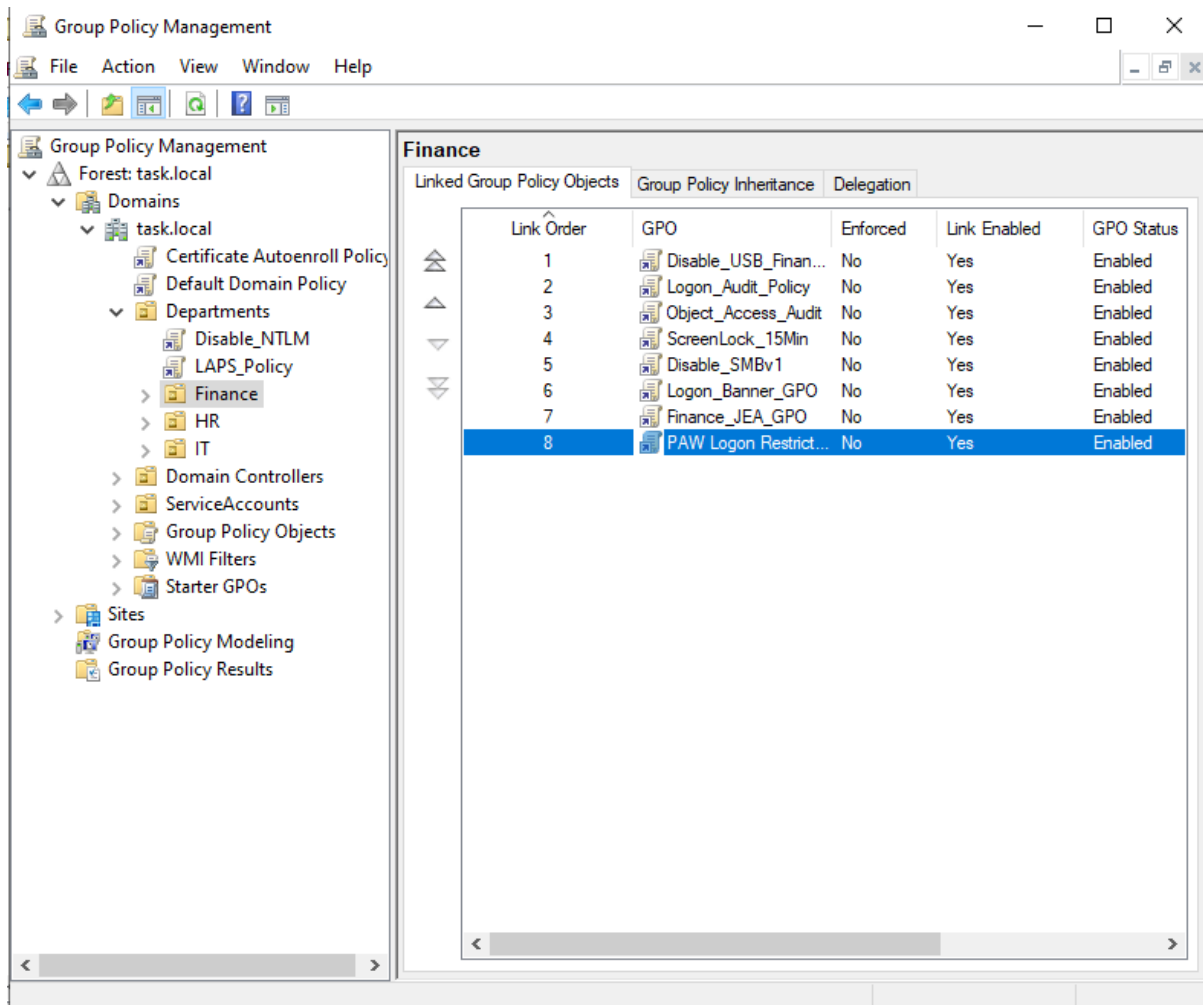


(The user Temp Admin was functional before, and access is now blocked due to automatic expiration, just as intended)

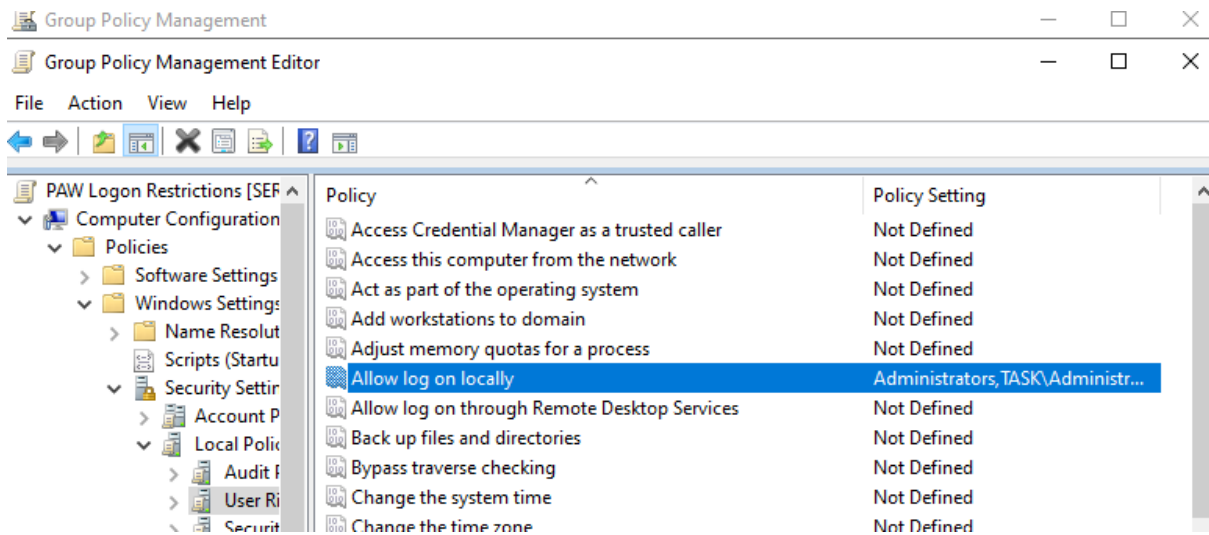
4.3 Set Up Privileged Access Workstations (PAWs) for Secure Admin Task

A second domain-joined workstation (PC1TEST) was prepared to function as a PAW. A new security group called PAW_Admns was created in Active Directory, and the Domain Administrator account was added to this group. Group Policy was then configured to:

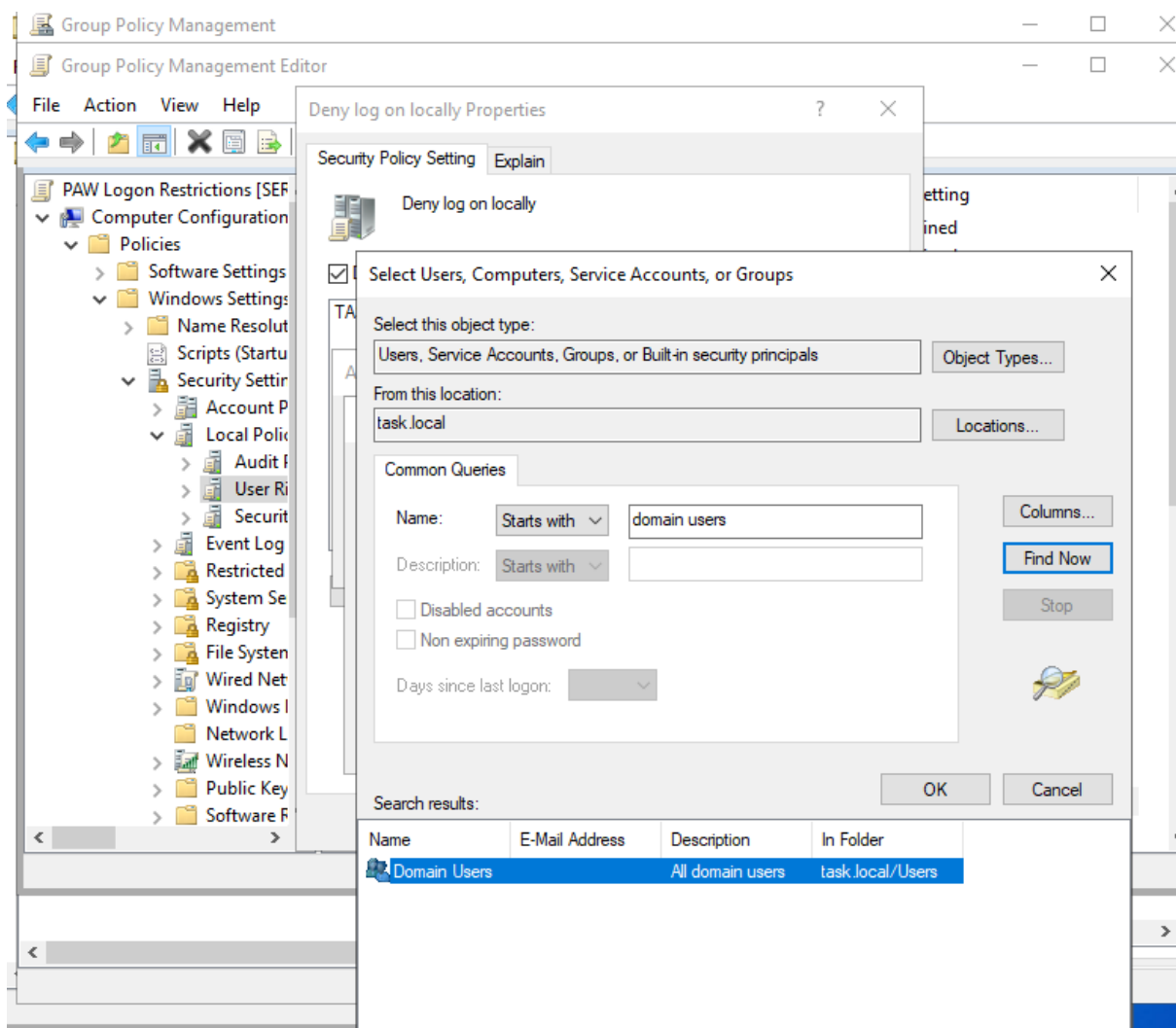
- Allow log on locally only to PAW_Admins.
- Deny log on locally to Domain Users. This configuration ensured that only authorized admin accounts could use PC1TEST. A login attempt using the Domain Admin account was successful while general users were denied access.



(create a new GPO – PAW Logon Restriction)



(edit policy to allow log on)



(edit policy to block log on)

Administrator: Windows PowerShell

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\administrator> gpupdate /force
Updating policy...

Computer Policy update has completed successfully.
User Policy update has completed successfully.
```

(update policy on PC1TEST)

```
PS C:\Users\administrator> gpresult /r

Microsoft (R) Windows (R) Operating System Group Policy Result tool v2.0
© Microsoft Corporation. All rights reserved.

Created on 5/15/2025 at 3:57:40 AM

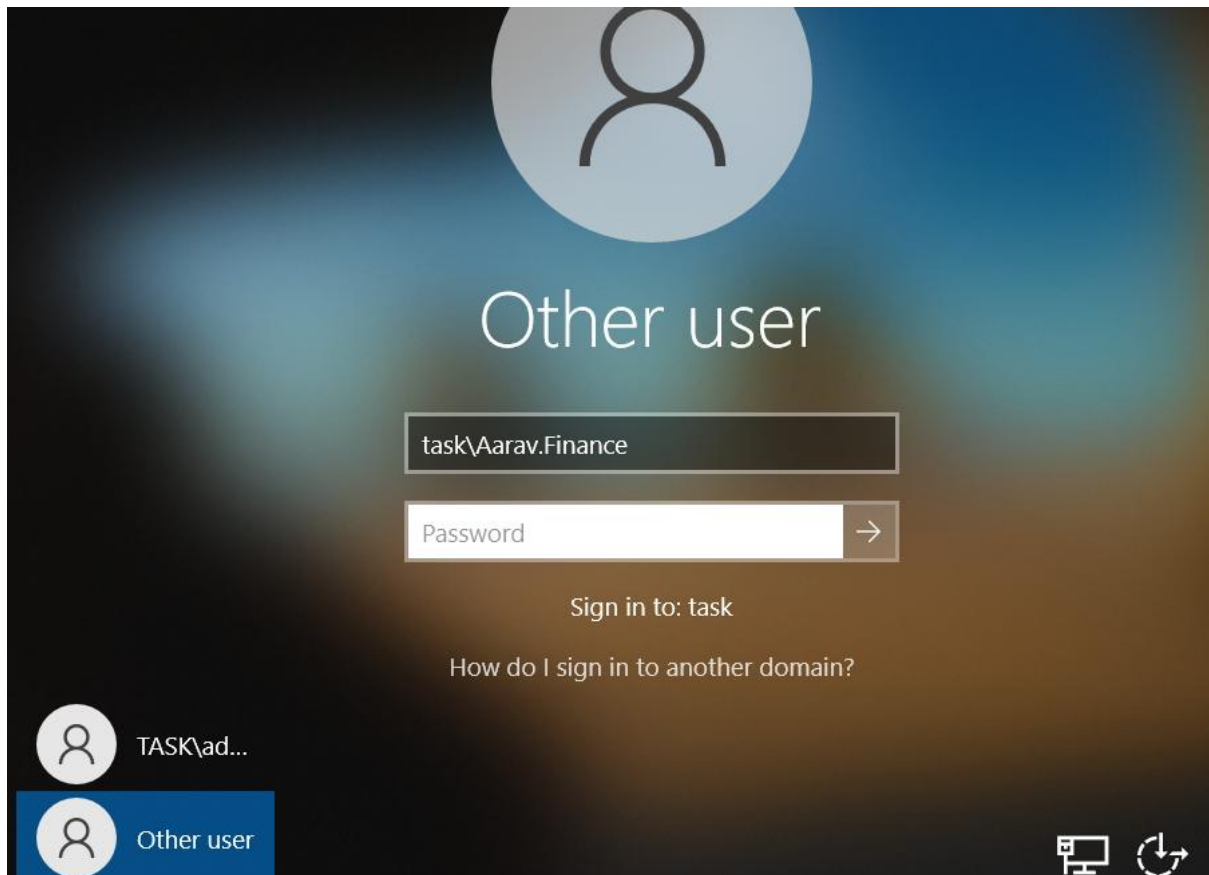
RSOP data for TASK\administrator on PC1TEST : Logging Mode
-----

OS Configuration:          Member Workstation
OS Version:                 10.0.19044
Site Name:                  Default-First-Site-Name
Roaming Profile:            N/A
Local Profile:              C:\Users\administrator
Connected over a slow link?: No

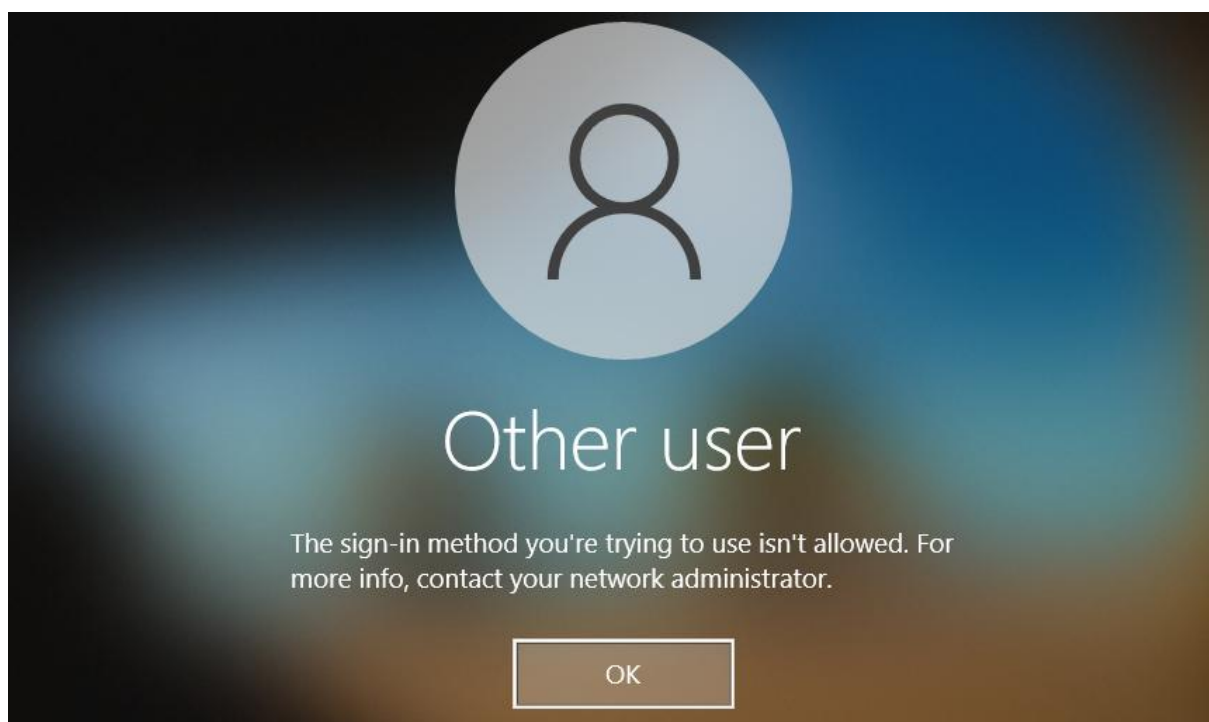
COMPUTER SETTINGS
-----
CN=PC1TEST,OU=Finance,OU=Departments,DC=task,DC=local
Last time Group Policy was applied: 5/15/2025 at 3:57:20 AM
Group Policy was applied from:   server1.task.local
Group Policy slow link threshold: 500 kbps
Domain Name:                    TASK
Domain Type:                   Windows 2008 or later

Applied Group Policy Objects
-----
  Disable_USB_Finance
  Logon_Audit_Policy
  Object_Access_Audit
  ScreenLock_15Min
  Disable_SMBv1
  Logon_Banner_GPO
  Finance_JEA_GPO
  PAW Logon Restrictions
  Disable_NTLM
  LAPS_Policy
  Default Domain Policy
  Certificate Autoenroll Policy
```

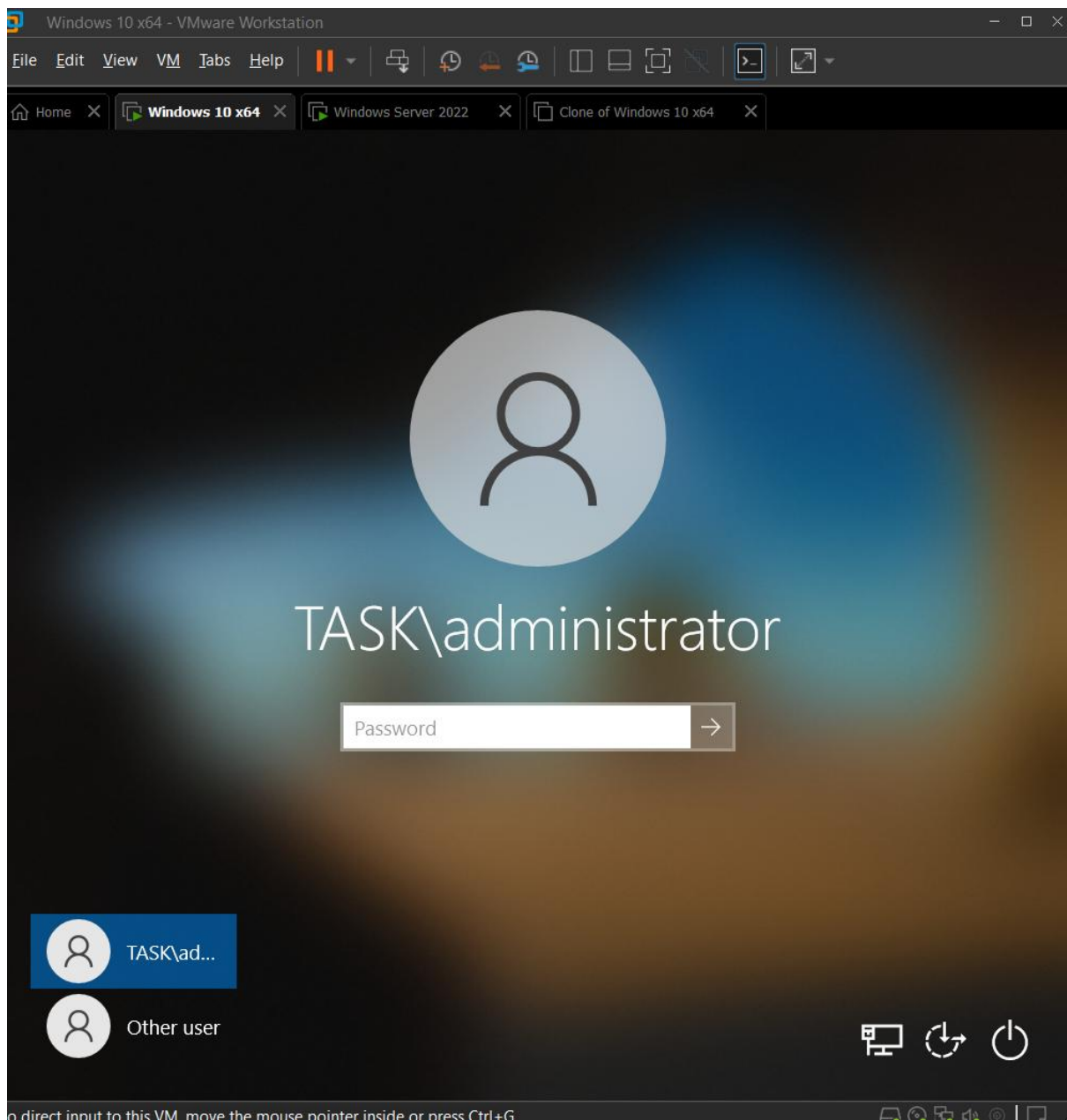
(in result we can see that we have updated policy successfully)



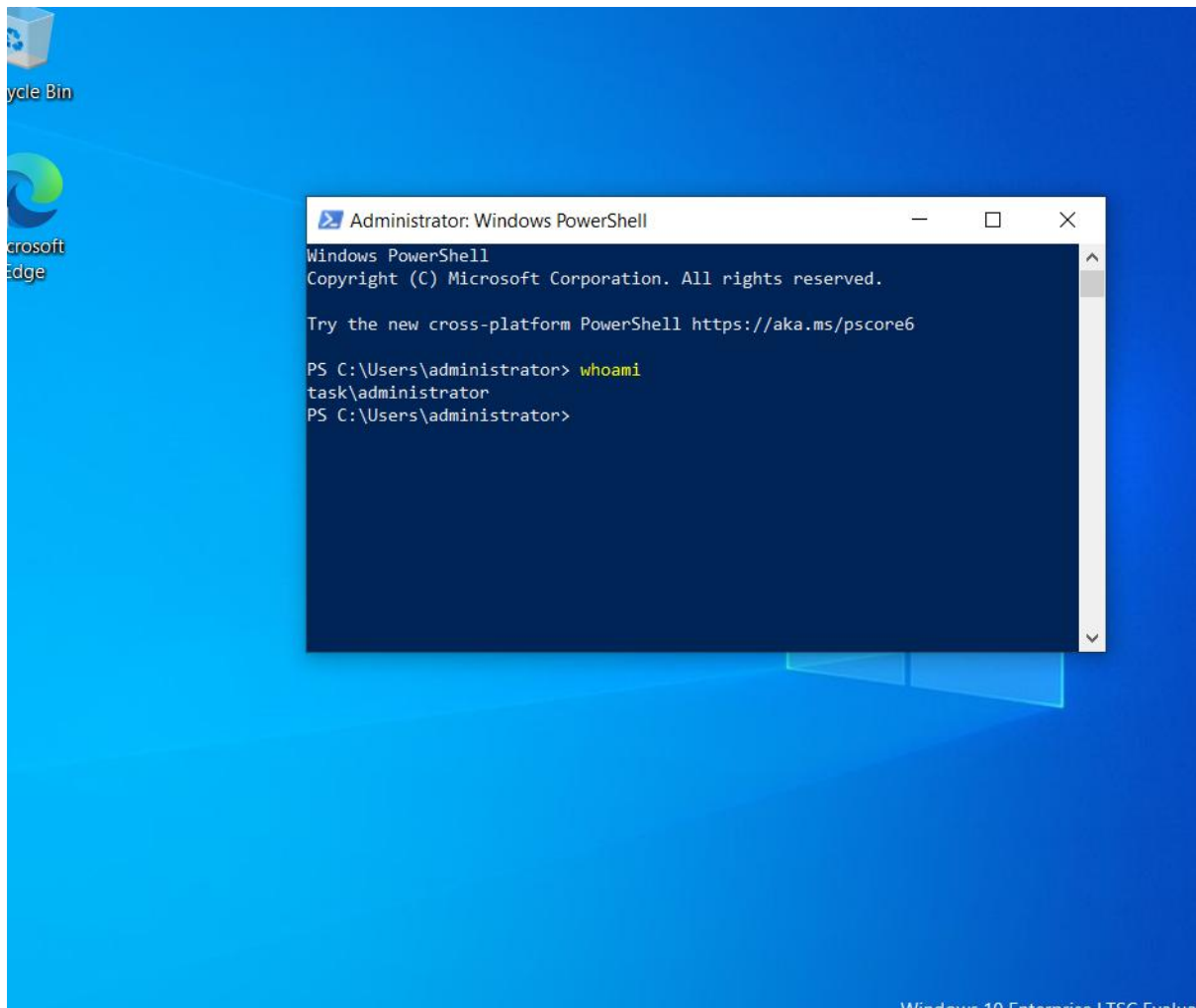
(try to log in as user)



(can't log in means we have succeeded in blocking user's to use this system)



(now let's try to login as administrator)



(and we can successfully log in as administrator)

5. Recommendations

- Apply JEA configurations to all lower-tier administrative accounts beyond helpdesk roles.
- Rotate and audit temporary accounts regularly, and set strict creation and expiration policies.
- Enforce usage of PAWs for all domain admins, and restrict PAW internet access to reduce exposure.
- Monitor WinRM logs to track JEA session usage.
- Periodically review Group Policy and session configuration files to ensure they align with current role responsibilities.

6. Conclusion

The successful implementation of JEA, time-limited admin accounts, and PAWs in our Active Directory environment significantly enhanced privileged access controls. JEA ensured Diya.Finance could only perform essential tasks without broader access, and the system blocked unauthorized commands. Temporary account expiration effectively enforced time-based access control, demonstrating account lockout after the defined period. Lastly, by isolating admin activities to PAWs and enforcing logon restrictions through Group Policy, we ensured that privileged credentials are not used on general-purpose systems. Collectively, these measures provide layered security and reduce the attack surface across our domain infrastructure.